

Learning from Failures: A Failure-Driven Prompt Refinement for LLM-Based Vulnerability Analysis

Mandana Ghadamian and David Mohaisen

University of Central Florida, Orlando, FL 32816, USA
 {mandana.ghadamian,mohaisen}@ucf.edu

Abstract. Large Language Models have emerged as promising tools for software vulnerability analysis, but their effectiveness depends heavily on prompt design. Existing research primarily compares prompting strategies using aggregate performance metrics, providing limited insight into why models fail or how prompts can be improved systematically. We propose **Failure-Driven Prompt Refinement (FDPR)**, a methodology that analyzes recurring model failures to guide evidence-based prompt refinement. Using the Damn Vulnerable Java Application (DVJA), we identify recurring failure modes, including false positives, false negatives, unsupported reasoning, and CWE misclassification, and translate them into targeted prompt refinements. We then evaluate the resulting prompt on the Juliet Test Suite and perform cross-model validation to assess generalizability. The results show that failure-driven refinement improves the reliability of LLM-based vulnerability analysis while yielding reusable prompt design principles. More broadly, this work demonstrates that recurring model failures provide a principled foundation for prompt engineering, enabling the systematic development of more reliable LLM-based vulnerability analysis systems.

1 Introduction

Software vulnerabilities remain a primary cause of security breaches [23,13], making accurate and scalable vulnerability detection a fundamental challenge in secure software development. Traditional static and dynamic analysis techniques improve software assurance but often fail to detect vulnerabilities that require semantic understanding, complex program context, or developer intent [31]. Recent advances in LLMs have shown strong capabilities in program comprehension, code generation, debugging, and vulnerability analysis, suggesting that they can complement conventional techniques by reasoning about source code using learned programming knowledge [25,3,17]. Consequently, LLM-assisted vulnerability analysis has become an active research area.

Despite this progress, deploying LLMs in security-critical workflows remains challenging [14]. Vulnerability analysis requires recognizing security-relevant patterns and producing evidence-based conclusions supported by the analyzed program [24]. In practice, LLMs hallucinate vulnerabilities, generate unsupported reasoning [28], misclassify Common Weakness Enumeration (CWE) categories [24], and overgeneralize from superficial code patterns [11]. These limitations reduce analyst trust, increase verification effort, and hinder the practical adoption of LLM-based vulnerability analysis.

Recent work has explored prompt engineering strategies for software vulnerability detection, including zero-shot prompting, few-shot prompting, role-based instructions, structured output constraints, and domain-specific context [14]. These studies consistently demonstrate that prompt design substantially affects model performance [31,4].

However, prompt refinement remains largely empirical. Existing approaches typically compare prompt variants using aggregate metrics such as accuracy, precision, recall, and F1-score [1]. While these metrics quantify overall performance, they provide limited insight into why models fail. Consequently, false positives, false negatives, unsupported reasoning, hallucinated evidence, and incorrect CWE assignments are treated as evaluation outcomes rather than engineering signals for systematic prompt refinement.

This limitation is reflected in inconsistent findings. Studies of prompting for software vulnerability detection report conflicting results for few-shot prompting, role prompting, and contextual guidance [16]. Some report substantial gains from few-shot prompting [8], whereas others find marginal improvements or degraded performance relative to zero-shot prompting [19]. Similar inconsistencies arise for other prompting strategies [4, 1]. These results suggest that prompt effectiveness depends on interactions among the model, dataset, task, and evaluation method, limiting the generalizability of benchmark-based guidelines [14]. We therefore ask three research questions: **RQ1:** Can recurring LLM failure patterns be systematically identified and organized to reveal prompt weaknesses in software vulnerability analysis? **RQ2:** Can iterative failure-driven prompt refinement improve the reliability and accuracy of LLM-based vulnerability detection? **RQ3:** What prompt design principles emerge from recurring failures, and do they generalize beyond the prompt-development dataset?

To answer these questions, we propose **Failure-Driven Prompt Refinement (FDPR)**, a systematic, evidence-driven methodology for prompt engineering. FDPR identifies recurring failures, infers their causes, organizes them into a taxonomy, prioritizes them by their impact on analyst trust and system reliability, and translates them into targeted prompt revisions. Iterative application of this process produces reusable prompt design principles that improve the reliability of LLM-based vulnerability analysis.

We evaluate FDPR for Java vulnerability detection using a two-stage design. We first refine prompts on the Damn Vulnerable Java Application (DVJA), enabling detailed analysis of model behavior and recurring failure patterns. We then evaluate the refined prompt on the Juliet Test Suite, a substantially larger benchmark spanning diverse CWE categories, to assess generalization beyond the development dataset. Our results show that FDPR substantially reduces unreliable vulnerability reports and shifts the remaining errors from unsupported reasoning to taxonomy-level classification errors. The contributions of this paper are as follows:

1. **Failure-Driven Prompt Refinement.** We introduce FDPR, a systematic methodology for improving prompts through iterative analysis of recurring LLM failures. FDPR combines structured failure analysis with evidence-driven prompt refinement, translating recurring failure patterns into targeted prompt modifications.
2. **Empirical Validation.** We develop FDPR using the Damn Vulnerable Java Application (DVJA) and evaluate the resulting prompt on the Juliet Test Suite. The results demonstrate that systematic failure analysis improves the reliability of LLM-based vulnerability analysis while generalizing beyond the development benchmark.
3. **Reusable Design Principles.** We derive reusable prompt design principles, including evidence-based reasoning, context-aware analysis, explicit uncertainty handling, and structured vulnerability classification. Although for software vulnerability, these principles may generalize to other LLM-based software engineering tasks.

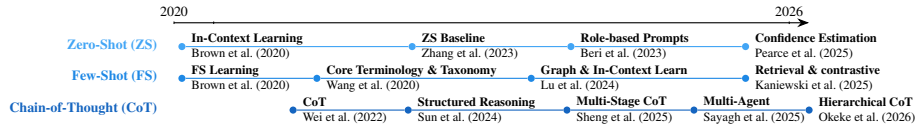


Fig. 1. Evolution of zero-shot, few-shot, and chain-of-thought prompting techniques relevant to LLM-based software vulnerability detection, from their foundational general-purpose formulations to increasingly specialized adaptations for this task.

2 Background

Prompt engineering is the primary approach for adapting LLMs to software vulnerability detection without modifying model parameters [32]. Rather than fine-tuning, prompts guide models through natural-language instructions and contexts during inference. Prompting techniques have evolved from simple task descriptions to structured reasoning, demonstrations, and multi-stage workflows that improve vulnerability detection. Fig. 1 summarizes the evolution of the three paradigms we consider.

Zero-Shot Prompting. Brown et al. showed that LLMs can perform downstream tasks through in-context learning without parameter updates [2]. Zero-shot prompting applies this capability to vulnerability detection by providing only task instructions and the target program. It has been widely adopted as a baseline across benchmark datasets and commercial LLMs [32]. More recent work augments zero-shot prompts with role-based instructions, confidence estimation, and security-oriented templates to improve reasoning consistency without demonstrations [23].

Few-Shot Prompting. Few-shot prompting extends zero-shot prompting by including a small number of demonstrations, allowing models to infer task objectives without additional training [2]. It is widely recognized as an effective adaptation strategy for foundation models [29]. In vulnerability detection, demonstrations typically include representative vulnerable and benign code, CWE descriptions, and structured reasoning examples. Recent work has explored graph-based demonstrations, similarity-based retrieval, contrastive vulnerable-patched pairs, and automatically generated examples to improve detection accuracy [14].

Chain-of-Thought Prompting. Chain-of-Thought (CoT) prompting improves performance by eliciting intermediate reasoning steps [30]. In vulnerability detection, CoT encourages models to analyze program behavior before identifying security weaknesses. Recent work has introduced structured reasoning stages, hierarchical and multi-stage prompting, self-consistency, Tree-of-Thought prompting, and multi-agent collaboration to improve vulnerability localization and CWE classification.

These advances demonstrate the value of structured prompting for LLM-based vulnerability analysis. FDPR builds on this foundation by systematically refining prompts based on recurring failure patterns rather than ad hoc prompt engineering.

3 Related Work

Traditional Software Vulnerability Detection. Deep learning shifted vulnerability detection from engineered features to learned representations. Representative approaches include token-based models, semantic code gadgets [18], graph neural networks [34],

program-slicing representations, and Transformer-based models capable of vulnerability localization [12]. While these methods improved accuracy, they rely on fixed learned representations and require retraining to adapt to new vulnerability patterns.

Datasets and Benchmarking. Progress in vulnerability detection has been driven by increasingly realistic benchmarks. Recent datasets improve label quality through differential analysis [33], support multilingual evaluation, increase project and CWE diversity [5], reduce duplication and labeling errors [7], and provide controlled micro-benchmarks [10]. These studies show that benchmark quality strongly influences reported performance and that many approaches fail to generalize across datasets.

LLM-Based Vulnerability Detection. LLMs have recently been applied to vulnerability classification, localization, and security reasoning [20,15]. Existing studies consistently report that LLMs recognize common vulnerability patterns but remain prone to false positives, unreliable reasoning, weak localization, and inconsistent vulnerability classification [26,28]. Prompt engineering, retrieval augmentation, and program-analysis-derived context partially mitigate these limitations [32,30,4,27,9,31], although their effectiveness varies across models, datasets, and tasks.

Prompt Refinement. Most prompt engineering studies compare predefined prompting strategies or optimize prompts using benchmark performance [6]. Although these approaches improve accuracy, they treat model failures as evaluation outcomes rather than diagnostic evidence for refinement. Consequently, they provide limited guidance for systematically improving prompt reliability.

Positioning of FDPR. FDPR complements existing prompt engineering by focusing on the refinement process rather than individual prompting strategies. It systematically identifies recurring failure modes, attributes them to specific reasoning deficiencies, and translates them into targeted prompt revisions. Rather than introducing a new prompting technique, FDPR provides an evidence-driven methodology for developing reliable prompts for LLM-based software vulnerability analysis.

4 Methodology

4.1 Overview

Prompt engineering for vulnerability detection is often guided by aggregate metrics; precision, recall, and F1-score, which quantify performance but provide little insight into why models fail or how prompts should evolve. FDPR instead treats failures as the refinement signal: each failure is analyzed, categorized into recurring failure types, prioritized by its impact, and translated into a targeted prompt refinement. As shown in Fig. 2, FDPR iteratively performs ① failure observation and root-cause analysis, ② taxonomy construction and prioritization, ③ failure-guided prompt refinement, ④ prompt re-evaluation, and ⑤ design principle extraction until further refinements no longer improve performance or the remaining failures reflect inherent model limitations. The resulting prompt is an artifact of the methodology, not its primary contribution.

4.2 Failure Analysis

Failure Observation. FDPR begins by systematically analyzing model outputs to identify failures. A failure is any output that violates the requirements of reliable vulnerability detection, including incorrect vulnerability identification, unsupported reasoning,

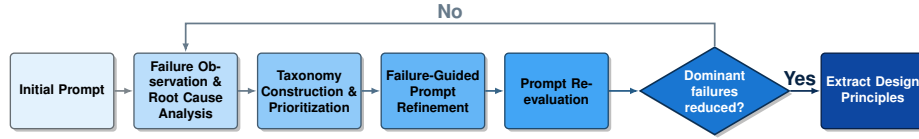


Fig. 2. Overview of the FDPR cycle. Each iteration transforms observed failures into prioritized prompt refinements until dominant failure categories are substantially reduced.

incorrect CWE classification, false positives, false negatives, and malformed responses. Each failure is recorded together with the model output, ground truth, and supporting source-code context to preserve the evidence required for subsequent analysis.

Root Cause Analysis. Each failure is analyzed to identify the underlying mechanism rather than treating all incorrect outputs as equivalent. Specifically, we determine (1) what the model produced, (2) why it is incorrect, (3) which reasoning mechanism caused the failure, and (4) what prompt modification could prevent it. This distinguishes failures attributable to prompt design from those arising from model limitations, ambiguous program semantics, or the evaluation pipeline.

Failure Taxonomy. Recurring root causes are grouped into a taxonomy of failure categories based on the reasoning deficiencies that produced them rather than their observable outcomes. This abstraction transforms isolated failures into recurring patterns that can be systematically addressed through prompt refinement.

Failure Prioritization. Failure categories are prioritized according to their prevalence, security impact, verification cost, recurrence, and expected responsiveness to prompt refinement. Each refinement cycle targets the highest-priority category, ensuring that prompt modifications address the most consequential and actionable failures first.

4.3 Failure-Driven Prompt Refinement

Following failure prioritization, FDPR translates the highest-priority failure category into targeted prompt modifications. Rather than relying on intuition or trial and error, each refinement is explicitly linked to a recurring failure mechanism identified during the preceding analysis. **❶ Refinement Objective.** The prioritized failure category is analyzed to identify the prompt deficiency responsible for the observed behavior and define a refinement objective that addresses the underlying cause while minimizing unintended effects on unrelated model behavior. **❷ Prompt Modification.** The refinement objective is translated into one or more prompt modifications, including clarifying task instructions, strengthening reasoning constraints, introducing structured output requirements, or incorporating representative few-shot examples. Every modification is directly traceable to the failure category it is intended to mitigate. **❸ Iterative Refinement.** Prompt modifications are introduced incrementally and evaluated after each iteration. This isolates the effect of individual changes, enables systematic analysis of their impact, and reduces the risk of introducing new failure modes. The refinement process continues until further modifications yield no meaningful improvement or the remaining failures are attributable to factors beyond prompt design.

4.4 Iterative Refinement Process

FDPR follows an iterative refinement process in which each prompt revision is evaluated to determine whether the targeted failure category has been reduced and to identify

newly emerging failure modes. After each iteration, the updated prompt is executed on the development dataset, and the resulting outputs undergo the failure analysis described above. This feedback loop ensures that subsequent refinements are driven by empirical observations rather than assumptions about model behavior. **① Incremental Refinement:** Each iteration targets a single prioritized failure category before introducing additional changes. This isolates the effect of individual prompt modifications, enables systematic evaluation of their contribution, and reduces the risk of introducing new failure modes. **② Stopping Criterion:** Refinement continues until further prompt modifications yield no meaningful improvement or the remaining failures are attributable to factors beyond prompt design, such as model limitations or ambiguous program semantics. The resulting prompt is then frozen and evaluated on an independent benchmark.

4.5 Design Principle Extraction

FDPR aims to improve an individual prompt and derive reusable principles. Across successive refinement iterations, prompt modifications that consistently mitigate recurring failure categories are abstracted into general design principles rather than retained as prompt-specific adjustments. **① Generalization:** A refinement strategy is promoted to a design principle only if it consistently reduces the targeted failure category across multiple failure instances and refinement iterations. Modifications that improve only isolated cases remain prompt-specific refinements. **② Reusable Knowledge:** The resulting design principles capture the rationale behind successful refinements and provide reusable guidance for prompt development in software vulnerability analysis. By abstracting transferable refinement strategies rather than individual prompt modifications, FDPR produces knowledge that extends beyond a single prompt or benchmark.

5 Experimental Setup

We evaluate FDPR using a two-phase design. Prompt refinement is performed exclusively on the Damn Vulnerable Java Application (DVJA), while the final prompt is frozen and evaluated on the Juliet Test Suite without further modification. This separation prevents benchmark leakage and evaluates whether the refinement methodology generalizes beyond the development environment.

Datasets. We use two datasets. **① Damn Vulnerable Java Application (DVJA).** DVJA serves as the development dataset for iterative prompt refinement. It contains 13 intentionally vulnerable Java programs covering the OWASP Top 10 (2013) categories. Its documented vulnerabilities and CWE mappings enable manual inspection of model outputs, construction of the failure taxonomy, and iterative prompt refinement. **② Juliet Test Suite.** The Java version of the Juliet Test Suite (v1.3) serves as the external validation benchmark. It contains approximately 40,845 Java programs spanning 112 CWE categories. To prevent benchmark leakage, vulnerability annotations, CWE-revealing comments, and identifying file and directory names are removed before evaluation. Ground-truth labels are used exclusively for performance evaluation.

Models. Prompt refinement used four locally hosted LLMs: Qwen3-Coder-30B, Qwen3.5-35B, DeepSeek-Coder-6.7B, and Llama-3.2-3B. External validation was performed using Qwen3-Coder-30B and Qwen3.5-35B, the two strongest-performing models during

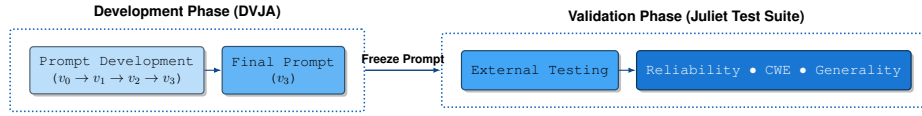


Fig. 3. Overview of the prompt development pipeline. The development phase (DVJA) iteratively refines the prompt through FDPR cycles ($v_0 \rightarrow v_1 \rightarrow v_2 \rightarrow v_3$) to produce a final prompt, which is frozen and carried into the validation phase (Juliet Test Suite) for external testing and evaluation of reliability, CWE coverage, and generality.

PROMPT VERSION	OUTCOME	FAILURE-GUIDED DESIGN DECISIONS
v0 MINIMAL PROMPT Baseline behavior; natural failure patterns	111 findings High unsupported / hallucinated rate	Basic Detection Instruction Vulnerability detection request with CWE identification Structured JSON Output Fixed output schema with no reasoning constraints
v1 FEW-SHOT PROMPT Hallucinated findings; unstable output structure	49 findings Noise reduced; pattern- based reasoning remained	Vulnerable / Non-vulnerable Examples Few-shot exemplars anchoring expected model behavior Output & Constraint Guidance Explicit reporting constraints reduce malformed responses
v2 EVIDENCE-BASED PROMPT Unsupported claims; keyword-driven reasoning	37 findings Fewer false positives; more conservative	Source-to-Sink Reasoning Requires input, propagation, and sink evidence chain Uncertainty Handling Permits rejecting findings lacking sufficient evidence
v3 FINAL REFINED PROMPT CWE errors from artificial taxonomy constraints	26 findings Substantially more reliable findings	Unrestricted CWE Reasoning Removed predefined Top-25 CWE scope restriction Corrected Inference Pipeline System prompt no longer concatenated with file content
Derived via FDPR		Observation Root Cause Taxonomy Prioritized Refinement

Fig. 4. Prompt versions produced by FDPR. Each version’s design decisions are directly traceable to the dominant failure category identified in the preceding refinement iteration; the outcome column reports the number of manually validated findings on DVJA after each revision.

development. All models were served through Ollama with temperature set to 0. Context length, output limits, and quantization used each model’s default configuration.

Experimental Pipeline. Fig. 3 summarizes the evaluation workflow. Prompt refinement iteratively produced four prompt versions (v0–v3) using DVJA. After refinement, the final prompt (v3) was frozen and evaluated on the Juliet Test Suite without modification.

System Prompt. The final prompt assigns the model the role of a security auditor and requires evidence-backed source-to-sink reasoning before reporting a vulnerability. It incorporates contrastive vulnerable and non-vulnerable examples, suppresses unsupported findings, and enforces a structured JSON output containing the vulnerability location, CWE, confidence score, and evidence chain (`input_source`, `propagation`, `sink`, and `sanitized`). Earlier prompt versions introduced these constraints incrementally throughout the refinement process (Figure 4).

Input Formatting. Each source file is analyzed independently using a single-turn request with file path and source code. No conversation history is retained across files. Juliet programs are preprocessed to remove vulnerability annotations and CWE identifiers, whereas DVJA source files are analyzed without modification.

Prompt Evolution. FDPR produced four prompt versions (v0–v3), illustrated in Figure 4. Each revision addressed the dominant failure category identified during the previous iteration, progressively reducing unsupported findings and improving reasoning consistency. The final prompt (v3) was used throughout external validation.

Table 1. Evolution of generated findings during prompt refinement.

Version Refinement		Findings	Primary Observation
v0	Baseline	111	Frequent unsupported and hallucinated findings
v1	Improve reporting	49	Reduced noise; pattern-based reasoning remained
v2	Evidence-based reasoning	37	Fewer false positives; more conservative analysis
v3	Remove CWE restrictions	26	Most reliable and consistent results

Evaluation. We combine quantitative evaluation with qualitative failure analysis. Quantitative metrics measure vulnerability detection performance against ground-truth labels, while qualitative analysis assesses the reliability of model-generated reports.

Quantitative Evaluation. We report precision, recall, F1-score, and CWE classification accuracy using three matching criteria:

- **Level 1 (Strict):** File, line number, and CWE category match.
- **Level 2 (Moderate):** File and CWE category match.
- **Level 3 (Relaxed):** CWE category match only.

Level 2 serves as the primary evaluation metric because source-to-sink vulnerabilities frequently span multiple lines while representing the same underlying weakness. During prompt refinement on DVJA, qualitative analysis guided prompt revisions, with quantitative results used to prioritize failure categories. External validation on the Juliet Test Suite uses Level 2 metrics, reported as Detection Rate and CWE Accuracy.

Qualitative Failure Analysis. Every reported vulnerability was manually reviewed to assess (i) correctness of the vulnerability claim, (ii) correctness of the assigned CWE, (iii) availability of supporting source-code evidence, (iv) consistency of the reasoning with the program logic, and (v) hallucinated or fabricated evidence. This analysis complements quantitative metrics by evaluating the reliability of model-generated security reports. Following each refinement iteration, incorrect findings were classified according to their underlying failure mechanism rather than their observable outcome. For example, reporting a vulnerability solely because a variable is named `password` is categorized as *security-pattern over-generalization*, whereas inventing a nonexistent authentication or data-flow path is categorized as *hallucinated evidence*. The resulting failure labels directly guided subsequent prompt refinements.

6 Results and Failure Analysis

This section presents the results of the failure-driven prompt refinement process on DVJA and the external evaluation of the final prompt on the Juliet Test Suite.

6.1 Prompt Refinement Outcomes

Prompt refinement improved the reliability of model-generated reports by reducing unsupported findings, hallucinated evidence, and incorrect vulnerability reasoning. Table 1 summarizes the evolution of model outputs across the four refinement iterations.

Reported findings decreased from 111 in the baseline prompt (v0) to 26 in the final prompt (v3). This reduction reflects improved precision rather than lower detection capability. Manual analysis showed that successive refinements eliminated unsupported

vulnerability claims, hallucinated evidence, and keyword-driven false positives, producing fewer but substantially more reliable security reports. Each refinement targeted the highest-priority failure category identified during the previous iteration. Early revisions focused on reducing unsupported findings, subsequent revisions strengthened evidence-based reasoning, and the final revision removed artificial constraints on CWE prediction. As the refinement progressed, obvious reasoning failures became less frequent, allowing the remaining errors to be analyzed at a finer level of granularity.

To complement the qualitative analysis, we measured recall across the ten OWASP Top 10 (2013) categories represented in DVJA. At baseline (v0), no individual model recovered all categories: qwen3-coder:30B identified 6/10 (60%), qwen3.5:35B identified 8/10 (80%), deepseek-coder:6.7B identified 0/10 (0%), and llama3.2:3B identified 1/10 (10%). The combined findings of all four models nevertheless covered all ten categories, albeit with the high false-positive rate reflected in the 111 reported findings.

After refinement (v3), the combined results covered all ten OWASP categories, but with zero false positives verified for each individual model. The 26 reported findings all corresponded to valid OWASP categories and frequently contained multiple correct CWE-level findings within a single category rather than spurious additional categories.

Manual inspection further showed that several apparent misses reflected evolution of the OWASP taxonomy rather than incorrect vulnerability reasoning. For example, Missing Function Level Access Control, Sensitive Data Exposure, and Cross-Site Request Forgery were reorganized under broader categories in later OWASP revisions [21,22]. When these taxonomy changes are taken into account, qwen3-coder:30B and qwen3.5:35B achieve taxonomy-adjusted recall of 10/10 (100%). Applying the same analysis to deepseek-coder:6.7B and llama3.2:3B yields taxonomy-adjusted recall values of 4/10 (40%) and 6/10 (60%), respectively. We therefore report both strict recall, based on the original OWASP 2013 labels, and taxonomy-adjusted recall, which credits semantically equivalent classifications under later OWASP revisions. Because the analyses for deepseek-coder:6.7B and llama3.2:3B were performed at a lower level of granularity than those for qwen3-coder:30B and qwen3.5:35B, their taxonomy-adjusted recall values should be interpreted as preliminary.

We report only the v0 baseline and the v3 endpoint. Per-model recall was not tracked for the intermediate prompt versions, and only the zero-false-positive result was verified individually at v3, which we acknowledge as a limitation.

6.2 Baseline Failure Analysis (v0)

Manual analysis of the baseline outputs (v0) showed that most incorrect predictions are from a small number of recurring reasoning failures rather than isolated model mistakes. Across the evaluated models, three dominant failure categories consistently emerged: evidence hallucination, security pattern over-generalization, and incorrect CWE classification. These recurring failures guided the subsequent prompt refinement process.

Evidence Hallucination The most severe baseline failure was the generation of reports unsupported by the analyzed source code. Models frequently inferred vulnerabilities from security-related identifiers or fabricated program behavior that did not exist. For example, variables named `password` were classified as hardcoded credentials despite the absence of assigned values, authentication logic, or credential exposure.

Table 2. Representative reasoning errors during the baseline evaluation (v0).

Observed Behavior	Incorrect Reasoning
Password variable	Assumed hardcoded credentials (CWE-798)
Database operation	Assumed SQL injection (CWE-89)
HTML output	Assumed XSS without supporting evidence

These errors indicate that the models attempted to satisfy the vulnerability detection objective without establishing sufficient evidence. This observation motivated the introduction of explicit evidence requirements, allowing the model to abstain when the available evidence was insufficient rather than forcing a vulnerability prediction.

Security Pattern Over-Generalization A second recurring failure was excessive reliance on lexical security patterns. Models associated database operations with SQL injection, HTML output with cross-site scripting, and security-related variable names with credential exposure without verifying that the necessary exploitation conditions were present. These observations demonstrate that recognizing security-related concepts is not equivalent to identifying exploitable vulnerabilities. Consequently, later prompt revisions required explicit reasoning over the source, propagation path, sink, and sanitization before reporting a vulnerability. This refinement substantially reduced keyword-driven false positives in subsequent iterations.

CWE Classification Errors The baseline analysis also showed that vulnerability identification and CWE classification are distinct reasoning tasks. Models often recognized the underlying security weakness while assigning an incorrect or overly general CWE identifier. Representative examples are summarized in Table 2. These observations indicate that identifying a vulnerability and assigning the correct CWE require different reasoning capabilities. Consequently, prompt refinement treated vulnerability identification and CWE classification as separate stages rather than a single prediction task.

6.3 Failure Taxonomy and Prompt Refinement

The recurring failure mechanisms identified during the baseline analysis were consolidated into the failure taxonomy shown in Table 3. Rather than prioritizing failures solely by frequency, the taxonomy ranks them according to their impact on report reliability, analyst confidence, verification effort, and their suitability for mitigation through prompt refinement. The taxonomy served as the roadmap for prompt refinement. Each refinement iteration targeted the highest-priority failure category, translated its underlying cause into a corresponding prompt modification, and re-evaluated the updated prompt before addressing subsequent categories. This iterative process progressively eliminated dominant sources of unreliable behavior, enabling later iterations to focus on increasingly subtle reasoning and CWE classification errors.

6.4 External Validation on the Juliet Test Suite

To evaluate whether the refinement principles derived from DVJA generalize beyond the development dataset, the final prompt (v3) was evaluated on the Juliet Test Suite

Table 3. Failure taxonomy derived during prompt refinement.

Failure Category	Observed Behavior	Underlying Cause	Refinement Objective
Evidence hallucination	Unsupported claims	Missing evidence	Require code evidence
Pattern over-gen.	Keyword-based reports	Lexical reasoning	Require source-to-sink reasoning
CWE taxonomy errors	Incorrect CWE assignment	Weak hierarchy navigation	Separate reasoning from classification
Over-reporting	Report every suspicion	No uncertainty handling	Allow abstention
Taxonomy constraints	Forced CWE mapping	Restricted CWE scope	Remove CWE restrictions

Table 4. Juliet evaluation configuration.

Component	Configuration	Component	Configuration
Dataset	Juliet Test Suite (Java)	Prompt	Final FDPR prompt (v3)
Models	Qwen3-Coder-30B; Qwen3.5-35B	CWE scope	None
Preprocessing	Comments removed; file paths blinded	Evaluation	File-level CWE classification

Table 5. Overall model performance on the Juliet Test Suite with Predictions (Pr), Files Flagged (FF), Files Processed (FP), and Detection Rate (DR).

Model	Pr	FF	FP	DR	CWE Accuracy	Unique CWEs
qwen3-coder:30B	34,084	31,782	40,863	77.8%	97.0%	86
qwen3.5:35B	4,398	4,201	11,078	37.9%	93.4%	100

without further modification. Evaluation used preprocessed source code in which vulnerability comments, CWE identifiers, and identifying directory names were removed, ensuring that predictions were based solely on program behavior rather than benchmark metadata. Table 4 summarizes the evaluation configuration.

The evaluation processed 54,440 records, comprising 38,482 vulnerability predictions and 15,958 sentinel records. Sentinel records indicate files for which the model reported no vulnerability and are included only to verify complete dataset coverage; they carry no CWE label and are excluded from all reported performance metrics.

Overall Performance Table 5 summarizes the overall results. Both models maintained high CWE classification accuracy after applying FDPR. Although their detection rates differed, the models were evaluated on different subsets of Juliet due to computational constraints and should therefore not be compared directly. Instead, the results demonstrate that the refinement methodology transfers successfully to both a code-specialized model and a general-purpose LLM.

Across both models, 37,154 of 38,482 reported vulnerabilities received the correct CWE label, corresponding to an overall classification accuracy of 96.5%.

Classification accuracy was consistently high for vulnerability classes with well-defined semantic boundaries, including SQL injection, OS command injection, LDAP injection, HTTP header injection, divide-by-zero, and integer overflow. These results indicate that once unsupported reasoning and artificial taxonomy constraints were removed through FDPR, the models were able to assign CWE identifiers with high consistency across a broad range of vulnerability categories.

6.5 Analysis of Remaining Errors

Although the final prompt substantially reduced unsupported reasoning and unreliable vulnerability reports, manual analysis showed that the remaining errors were dominated

Table 6. Representative examples of CWE hierarchy collapse.

Expected	Predicted	Interpretation
CWE-80	CWE-79	Generic XSS selected instead of the specific subtype
CWE-81	CWE-79	Error-message XSS mapped to its parent category
CWE-83	CWE-79	Attribute-based XSS mapped to its parent category

by taxonomy navigation rather than vulnerability recognition. Of the 1,328 incorrect CWE predictions, most reflected selection of an incorrect level within the CWE hierarchy rather than failure to identify the underlying security weakness.

Hierarchy Collapse The most common remaining error was *CWE hierarchy collapse*, accounting for 978 misclassifications (73.6%). In these cases, the models correctly identified the vulnerability family but predicted a broader parent CWE instead of the more specific child CWE expected by Juliet. Representative examples are shown in Table 6.

Although incorrect under exact matching, these predictions show models generally recognized the underlying vulnerability while failing to navigate CWE granularity.

Other Taxonomy Errors Credential-related errors accounted for 206 incorrect predictions (15.5%), primarily reflecting confusion between CWE-259 (Hardcoded Password) and its parent CWE-798 (Hardcoded Credentials). Path-related errors accounted for 71 incorrect predictions (5.3%), where specific variants such as CWE-23 and CWE-36 were mapped to the broader CWE-22. Together, hierarchy collapse, credential ambiguity, and path-related ambiguity accounted for 1,255 of the 1,328 incorrect predictions (94.5%). The remaining 73 errors (5.5%) were infrequent and did not exhibit a dominant shared failure mechanism. These results indicate that, after prompt refinement, the primary limitation shifted from vulnerability recognition to selecting the appropriate level of abstraction within the CWE taxonomy.

Impact of Removing CWE Restrictions One of the final prompt refinements removed the predefined CWE scope imposed during earlier development iterations. Failure analysis showed that these restrictions occasionally forced correctly identified vulnerabilities into semantically related but incorrect CWE categories.

The Juliet evaluation validates this refinement. Without predefined CWE restrictions, the evaluated models correctly identified 86 and 100 unique CWE categories, respectively (Table 5), demonstrating that unrestricted taxonomy reasoning improves semantic classification across diverse vulnerability types.

Key Findings. The results lead to four primary observations. First, iterative prompt refinement reduced unsupported vulnerability reports, hallucinated evidence, and keyword-driven reasoning, producing fewer but more reliable security findings. Second, model failures clustered into a small number of recurring reasoning patterns that could be systematically addressed through targeted prompt refinements. Third, the resulting refinement principles generalized from the development dataset to the independent Juliet benchmark while maintaining high CWE classification accuracy. Finally, after refinement, the dominant remaining errors shifted from vulnerability recognition to CWE taxonomy navigation, where models more often selected an incorrect level of abstraction within the CWE hierarchy than failed to identify the vulnerability itself.

7 Discussion

The objective of FDPR is not to produce a single optimized prompt, but to establish a systematic methodology for improving prompt reliability through failure analysis. Rather than treating model failures as isolated prediction errors, FDPR views them as engineering evidence that can guide prompt refinement. The experimental results show that recurring failure patterns can be identified, categorized, prioritized, and systematically translated into targeted prompt modifications, moving prompt engineering beyond empirical trial-and-error toward an evidence-driven engineering process.

Beyond Trial-and-Error. Current prompting typically relies on iterative experimentation: prompts are modified, evaluated, and compared using aggregate metrics such as accuracy, precision, recall, or F1-score. Although effective for selecting among alternatives, these metrics provide limited insight into why a prompt succeeds or fails. Two prompts may achieve similar performance while exhibiting fundamentally different failure behaviors, such as hallucinating unsupported vulnerabilities or conservatively missing difficult cases. FDPR instead treats failures as the primary refinement signal. Rather than asking which prompt performs better, it asks why the model failed and what prompt modification addresses that failure. Each refinement follows the same systematic process: identifying recurring failure patterns, analyzing their underlying causes, prioritizing them according to practical impact, and translating them into targeted prompt modifications. This shifts prompt engineering from empirical optimization toward a reproducible engineering methodology grounded in observable model behavior.

Failure Prioritization. A distinguishing characteristic of FDPR is explicit failure prioritization. Rather than addressing the most frequent failures first, FDPR ranks failure categories according to their practical impact on analyst trust, verification effort, reliability, security consequences, recurrence, and feasibility of prompt-based mitigation.

This prioritization proved particularly important during prompt refinement. Early prompt versions produced many unsupported vulnerability reports. Although these increased apparent vulnerability coverage, they substantially reduced practical usability because every unsupported finding required manual verification. Consequently, reducing hallucinated evidence and unsupported reasoning was prioritized before improving CWE classification accuracy. This reflects an important distinction between benchmark optimization and practical deployment: a system that reports more vulnerabilities is not necessarily more useful if its findings cannot be trusted.

Evolution of Failure Modes. The refinement process also revealed that model failures evolved as prompt quality improved. Early iterations were dominated by evidence hallucination, unsupported reasoning, and pattern-based false positives, indicating that the models frequently relied on superficial lexical associations rather than semantic program analysis. As these behaviors were progressively eliminated, the remaining errors shifted toward navigation of the hierarchical CWE taxonomy.

This transition is significant because it demonstrates that prompt refinement improved more than benchmark performance. The dominant remaining errors were no longer failures to recognize vulnerabilities, but failures to select the appropriate level of abstraction within the CWE hierarchy. Such errors are substantially more interpretable and bounded than hallucinated vulnerability reports, suggesting that FDPR transforms unreliable reasoning into more understandable and explainable failure modes.

Broader Implications. Although evaluated in the context of software vulnerability analysis, FDPR is not inherently specific to cybersecurity. Many LLM-based software

engineering tasks, including code generation, automated repair, code review, and test generation, face similar challenges involving hallucinated outputs, unreliable reasoning, and limited explainability. Treating recurring failures as engineering evidence rather than isolated prediction errors provides a systematic methodology for improving prompt reliability across such applications. More broadly, this work suggests that prompt engineering should evolve from empirical prompt optimization into a reproducible engineering discipline. Rather than selecting among predefined prompting paradigms, reliable prompts may emerge by combining complementary prompting mechanisms guided by observed failure modes. In this view, evaluation metrics validate design decisions, while systematic failure analysis drives prompt evolution.

8 Conclusion

We present FDPR, a failure-driven methodology for refining prompts for LLM-based vulnerability detection. By analyzing recurring failures and translating them into targeted prompt refinements, FDPR improved detection reliability while making remaining errors more interpretable. More broadly, the work demonstrates that failure analysis can serve as a principled foundation for prompt engineering beyond trial-and-error.

References

1. Bae, J., Kwon, S., Myeong, S.: Enhancing software code vulnerability detection using gpt-4o and claude-3.5 sonnet: A study on prompt engineering techniques. *Electronics* **13**(13) (2024)
2. Brown, T., Mann, B., Ryder, N., Subbiah, M., Kaplan, J.D., Dhariwal, P., Neelakantan, A., Shyam, P., Sastry, G., Askell, A., et al.: Language models are few-shot learners. *Adv. Neural Inf. Process. Syst. (NeurIPS)* **33**, 1877–1901 (2020)
3. Camarato, S.J., Hmaiti, Y., Ghadamian, M., Mohaisen, D.: Promptaudit: Auditing prompt sensitivity in llm-based vulnerability detection. *arXiv preprint arXiv:2605.24171* (2026)
4. Ceka, I., Qiao, F., Dey, A., Valecha, A., Kaiser, G., Ray, B.: Can llm prompting serve as a proxy for static analysis in vulnerability detection. *arXiv preprint arXiv:2412.12039* (2024)
5. Chen, Y., Ding, Z., Alowain, L., Chen, X., Wagner, D.: Diversevul: A new vulnerable source code dataset for deep learning-based vul detection. In: *Proc. RAID*. pp. 654–668 (2023)
6. Chen, Z., Wang, C., Sun, W., Liu, X., Zhang, J.M., Liu, Y.: Promptware engineering: Software engineering for prompt-enabled systems. *ACM Trans. Softw. Eng. Methodol.* (2026)
7. Ding, Y., Fu, Y., Ibrahim, O., Sitawarin, C., Chen, X., Alomair, B., Wagner, D., Ray, B., Chen, Y.: Vulnerability detection with code language models: How far are we? *arXiv preprint arXiv:2403.18624* (2024)
8. Dozono, K., Gasiba, T.E., Stocco, A.: Large language models for secure code assessment: A multi-language empirical study. In: *Proc. IEEE/ACM DeepTest*. pp. 6–13 (2026)
9. Du, X., Zheng, G., Wang, K., Zou, Y., Wang, Y., et al.: Vul-rag: Enhancing llm-based vulnerability detection via knowledge-level rag. *ACM Trans. Softw. Eng. Methodol.* (2026)
10. Dubniczky, R.A., Horvát, K.Z., Bisztray, T., Ferrag, M.A., et al.: Castle: Benchmarking dataset for static code analyzers and llms towards cwe detection. In: *Proc. TASE* (2025)
11. Evertz, J., Risse, N., Neuer, N., Müller, A., et al.: Chasing shadows: Pitfalls in llm security research. *arXiv preprint arXiv:2512.09549* (2025)
12. Fu, M., Tantithamthavorn, C.: Linevul: A transformer-based line-level vulnerability prediction. In: *Proc. MSR*. pp. 608–620 (2022)
13. Jaffal, N.O., Alkhanafseh, M., Mohaisen, D.: Large language models in cybersecurity: A survey of applications, vulnerabilities, and defense techniques. *AI* **6**(9), 216 (2025)

14. Kaniewski, S., Schmidt, F., Enzweiler, M., Menth, M., Heer, T.: A systematic literature review on detecting software vulnerabilities with large language models. *ACM Trans. Softw. Eng. Methodol. (TOSEM)* (2026)
15. Khare, A., Dutta, S., Li, Z., Solko-Breslin, A., Alur, R., Naik, M.: Understanding the effectiveness of large language models in detecting security vulnerabilities. In: *Proc. IEEE ICST*. pp. 103–114 (2025)
16. Kharma, M., Sabbah, A., Alkhanafseh, M., Hammoudeh, M., Mohaisen, D.: An empirical evaluation of llm-generated code security across prompting methods. *arXiv preprint arXiv:2605.24298* (2026)
17. Kharma, M.F., Alkhanafseh, M., Sabbah, A., Mohaisen, D.: Enhancing reliability in llm-based secure code generation. *arXiv preprint arXiv:2605.24300* (2026)
18. Li, Z., Zou, D., Xu, S., Ou, X., Jin, H., Wang, S., Deng, Z., Zhong, Y.: Vuldeepecker: A deep learning-based system for vulnerability detection. *arXiv preprint arXiv:1801.01681* (2018)
19. Lin, J., Mohaisen, D., et al.: From large to mammoth: A comparative evaluation of large language models in vulnerability detection. In: *NDSS* (2025)
20. Liu, P., Liu, J., Fu, L., Lu, K., Xia, Y., Zhang, X., Chen, W., et al.: Exploring ChatGPT’s capabilities on vulnerability management. In: *Proc. USENIX Security*. pp. 811–828 (2024)
21. OWASP Foundation: OWASP top 10 – 2017: The ten most critical web application security risks. <https://owasp.org/www-project-top-ten/2017/> (2017)
22. OWASP Foundation: OWASP top 10 – 2021. <https://owasp.org/Top10/> (2021)
23. Pearce, H., Ahmad, B., Tan, B., Dolan-Gavitt, B., Karri, R.: Asleep at the keyboard? assessing the security of github copilot’s code contributions. *Commun. ACM* **68**(2) (2025)
24. Sayagh, M., Ghafari, M.: Think broad, act narrow: Cwe identification with multi-agent large language models. *arXiv preprint arXiv:2508.01451* (2025)
25. Sheng, Z., Chen, Z., Gu, S., Huang, H., Gu, G., Huang, J.: Llms in software security: A survey of vulnerability detection techniques and insights. *ACM CSUR* **58**(5), 1–35 (2025)
26. Steenhoek, B., Rahman, M.M., Roy, M.K., Alam, M.S., Barr, E.T., Le, W.: A comprehensive study of the capabilities of large language models for vulnerability detection. *arXiv preprint arXiv:2403.17218* **59** (2024)
27. Sun, Y., Wu, D., Xue, Y., Liu, H., Ma, W., Zhang, L., Liu, Y., Li, Y.: Llm4vuln: A unified evaluation framework for decoupling and enhancing llms’ vulnerability reasoning. *arXiv preprint arXiv:2401.16185* (2024)
28. Ullah, S., Han, M., Pujar, S., Pearce, H., Coskun, A., Stringhini, G.: Llms cannot reliably identify and reason about security vulnerabilities (yet?): A comprehensive evaluation, framework, and benchmarks. In: *Proc. IEEE S&P*. pp. 862–880 (2024)
29. Wang, Y., Yao, Q., Kwok, J.T., Ni, L.M.: Generalizing from a few examples: A survey on few-shot learning. *ACM Comput. Surv. (CSUR)* **53**(3), 1–34 (2020)
30. Wei, J., Wang, X., Schuurmans, D., Bosma, M., Xia, F., Chi, E., Le, Q.V., Zhou, D., et al.: Chain-of-thought prompting elicits reasoning in large language models (2022)
31. Yang, Y., Xu, B., Gao, X., Sun, H.: Context-enhanced vulnerability detection based on large language models. *ACM Trans. Softw. Eng. Methodol. (TOSEM)* **35**(8), 1–47 (2026)
32. Zhang, C., Liu, H., Zeng, J., Yang, K., Li, Y., Li, H.: Prompt-enhanced software vulnerability detection using chatgpt. In: *Proc. ICSE Companion*. pp. 276–277 (2024)
33. Zheng, Y., Pujar, S., Lewis, B., Buratti, L., Epstein, E., Yang, B., Laredo, J., Morari, A., Su, Z.: D2a: A dataset built for ai-based vulnerability detection methods using differential analysis. In: *Proc. ICSE-SEIP*. pp. 111–120 (2021)
34. Zhou, Y., Liu, S., Siow, J., Du, X., Liu, Y.: Devign: Effective vulnerability identification by learning comprehensive program semantics via graph neural networks. *Adv. Neural Inf. Process. Syst. (NeurIPS)* **32** (2019)